

Unifolio — Consumer-Facing MFA: Posture Statement

Document owner: Ahmed Al-Samak, CEO (security@unifolio.ca)

Effective date: 2026-05-13

Last reviewed: 2026-05-13

Status: Posture statement filed in response to Plaid Production Customer Agreement security questionnaire item Q4. **TOTP-based MFA has been deployed in production** (commit shipped 2026-05-13). This document supersedes the prior compensating-controls statement.

1. Statement

Unifolio supports multi-factor authentication for end-user sign-in to the Unifolio web application using **Time-based One-Time Passwords (TOTP)** via Supabase Auth's built-in `auth.mfa.*` flow. Users enroll an authenticator-app factor (Google Authenticator, 1Password, Authy, etc.) from **Settings → Security & Privacy → Two-Factor Authentication**; on next sign-in they are challenged for a 6-digit code before the session is upgraded to AAL2.

For accounts created on or after **2026-09-30**, enrollment of at least one verified TOTP factor is **mandatory before the user can connect a Plaid Item** — the in-app Plaid Connect button surfaces a "set up 2FA" gate until enrollment is complete. Accounts created before that cutover are grandfathered (existing users are encouraged but not forced to enroll, to avoid stranding active brokerage connections under sudden mandatory enrollment).

Plaid security questionnaire item Q4 — "Is multi-factor authentication used?" — is therefore answered: **Yes — non-phishing-resistant multi-factor authentication (TOTP) is performed for accounts that have enrolled, and is mandatory before Plaid Link for accounts created on or after 2026-09-30.**

2. Implementation summary

Aspect	Detail
MFA factor type	TOTP (RFC 6238) — 30-second time-step, 6-digit code
Identity provider	Supabase Auth (@supabase/supabase-js v2)

Consumer MFA Rationale and Compensating Controls · Unifolio Inc. · Generated 2026-05-14 · Canonical version: [github.com/2uay/unifolio](#)

Aspect	Detail
Enrollment surface	<code>src/components/settings/MfaEnrollment.jsx</code> (Settings page)
Sign-in challenge surface	<code>src/components/auth/MfaChallenge.jsx</code> (Welcome / login page)
Server-side gate	<code>src/components/plaid/PlaidConnectButton.jsx</code> checks <code>listMfaFactors()</code> for accounts created $\geq$ 2026-09-30 and renders a "Set up 2FA" affordance when no verified factor exists
Auth library calls	<code>auth.mfa.enroll()</code> , <code>auth.mfa.challenge()</code> , <code>auth.mfa.verify()</code> , <code>auth.mfa.unenroll()</code> , <code>auth.mfa.listFactors()</code> , <code>auth.mfa.getAuthenticatorAssuranceLevel()</code>
Audit-log events	<code>mfa_enrolled</code> , <code>mfa_unenrolled</code> , <code>mfa_challenge_succeeded</code> , <code>mfa_challenge_failed</code> written to <code>audit_log</code> per event (see <code>DATA_RETENTION_POLICY.md</code> §3.4)
Recovery	Users can re-enroll a new authenticator if they lose access, contingent on regaining their email account (account password reset is gated by email verification). Future work: backup codes; see §6.

3. Defence-in-depth controls (still in force)

These were the compensating controls listed in the prior version of this document. They remain in production as defence-in-depth — they are not weakened by adding MFA, they layer with it.

3.1 Mandatory email verification before activation

A new account is **inert** until the user clicks the verification link sent to their registered email address. They cannot connect Plaid Link, import broker statements, view any portfolio data, or persist any data to Unifolio's servers without first verifying email ownership. This is the floor that MFA layers on top of.

3.2 Password strength enforcement and brute-force protection

Supabase Auth enforces a minimum 8-character password length at signup and password change. Authentication attempts are rate-limited per IP and per account by Supabase's gotrue layer to defeat brute-force credential guessing. Supabase's HaveIBeenPwned breach-corpus check (Pro-tier feature) will be enabled when Unifolio upgrades from Supabase Free.

github.com/2uay/unifolio

3.3 Bcrypt password hashing with per-user salt

Passwords are stored as bcrypt hashes by Supabase Auth with the cost factor configured by the gotrue implementation. Even in the unlikely event of a database compromise, individual passwords cannot be recovered in any practical timeframe.

3.4 Postgres Row-Level Security on all sensitive data

Even if an attacker obtained a valid session for one user, every sensitive table in the Unifolio database has Row-Level Security policies enforcing `user_id = auth.uid()`. The attacker cannot pivot from one compromised account to another user's data.

3.5 Short-lived access tokens

Supabase Auth issues 1-hour access tokens with 7-day refresh tokens. A stolen token has limited persistence. The user can sign out from any device via Settings → Session.

3.6 No money-movement capability

Unifolio is a **read-only personal portfolio aggregator**. The product cannot initiate trades, move money, authorize ACH/EFT transactions, or change beneficiary information at any underlying institution. The blast radius of an account takeover is therefore read-access to the victim's portfolio summary — concerning from a privacy standpoint, but not financially actionable.

3.7 Read-only Plaid integration

Unifolio uses Plaid only for the read-only Investments and Transactions products. We do not use Plaid Auth, Transfer, Income, or any of the money-movement-capable products. A compromised Unifolio account cannot initiate a Plaid-mediated transfer because no such code path exists in the product.

3.8 User self-service deletion

A user who suspects their account has been compromised can permanently delete all their Unifolio data in three clicks (Settings → Privacy & Data → Delete All Data) without contacting support. The full-account-delete cascade clears every app-data table, hard-deletes the `plaid_items` rows, calls Plaid's `/item/remove` API for each Item (terminating the connection at the bank end), and removes the `auth.users` record so the account cannot be signed back into. See DATA_RETENTION_POLICY.md §3.1 for the exact server-side flow.

4. Updated threat model

Threat	Mitigation in place	Residual risk
Credential stuffing from a third-party	Email-verification gating + bcrypt hashing + Supabase rate-limited authentication + TOTP	Low for MFA-enrolled accounts; Medium for grandfathered

Threat	Mitigation in place	Residual risk
breach	MFA for enrolled accounts. (HIBP breach-corpus rejection enabled when Unifolio upgrades from Supabase Free.)	accounts that have not yet enrolled
Phishing of a Unifolio password	Email-verification gating + read-only product surface + TOTP MFA for enrolled accounts. TOTP is non-phishing-resistant — see §6.	Low for MFA-enrolled accounts; Medium for grandfathered accounts
Brute-force guessing of a weak password	Supabase rate-limiting + 8-character password minimum + TOTP MFA	Very low for MFA-enrolled accounts
Session hijacking via stolen browser token	1-hour token expiry + sign-out functionality	Low
Insider attack by Supabase / Vercel staff	Vendor SOC 2 II + DPA + no production access from Unifolio's side	Low
Account takeover leading to financial loss	Read-only product, no money movement, no trade execution	Very low
Account takeover leading to privacy breach (attacker views portfolio)	Email-verification gating + TOTP MFA for enrolled accounts	Low for MFA-enrolled accounts; Medium for grandfathered accounts (closes naturally as users enroll voluntarily)

The remaining "Medium" classifications are confined to the grandfathered cohort (accounts created before 2026-09-30 that have not yet enrolled TOTP). New accounts are subject to the mandatory gate at Plaid Link, so the cohort with residual risk shrinks monotonically over time.

5. Plaid attestation alignment

This deployment closes the gap noted in the prior version of this document. With reference to the Plaid Production Customer Agreement security questionnaire:

- **Q4 — "Is multi-factor authentication used?"**

Prior answer: "No — compensating controls (read-only product, email verification, RLS) in lieu of MFA. Roadmap commitment to deploy by 2026-09-30."

Updated answer (effective 2026-05-13): **"Yes — non-phishing-resistant multi-factor authentication (TOTP) is performed for accounts that have enrolled, and is mandatory before Plaid Link for accounts created on or after 2026-09-30."**

The deployment was completed ahead of the original Q3 2026 roadmap commitment.

6. Forward-looking work

The next consumer-facing authentication investment is **WebAuthn / passkey support** (phishing-resistant MFA per FIDO2). Supabase Auth has a WebAuthn beta path; Unifolio will adopt it once it leaves beta and stabilizes. Target window: 2027 H1, contingent on Supabase production-readiness.

Backup-code provisioning at enrollment time (so a user who loses their authenticator app can recover without contacting support) is on the same near-term horizon.

7. Review cadence

This rationale is reviewed:

- **Quarterly** for accuracy against the deployed implementation.
 - **Immediately** if Unifolio adds any product capability that introduces money-movement risk (e.g., portfolio rebalancing actions, ACH-backed payments) — in which case the MFA mandate would be extended to all accounts regardless of cohort, as a hard prerequisite to launching that capability.
 - **At the time of WebAuthn / passkey deployment**, after which Q4 of the Plaid questionnaire is re-answered as *"Yes — phishing-resistant multi-factor authentication is performed"* and this document is updated to reflect the new posture.
-

Acknowledgement

— Ahmed Al-Samak, CEO, Unifolio Inc.
2026-05-13